PROGRAM 1 / TEKNİK ARAŞTIRMA RAPORU

Microsoft Identity ve Hybrid Trust Protokol Invariyantları

Workload Identity Federation, OAuth 2.0 Token Exchange, OpenID Connect, Cloud Kerberos Trust, MS-PAC ve dMSA için deterministik doğrulama ve izole laboratuvar kanıtı.

37	25	198	0
FORMAL İNVARİYANT	NORMALİZE GÖZLEM	BAŞARILI TEST	DOĞRULANMIŞ ÜRÜN SAPMASI

Adil Alperen Çiftci
Principal Systems Engineer

Sürüm 1.0
30 Ekim 2026 / İstanbul

BELGE KONTROLÜ

Okuma rehberi ve kanıt sınırı

Bu rapor, Program 1 deposundaki gözden geçirilmiş katalog, normalize ledger ve manifest bağlarından üretilmiştir.

Belge kimliği

Başlık	Microsoft Identity ve Hybrid Trust Protokol Invariyantları
Belge türü	Teknik araştırma ve doğrulama raporu
Kanıt dönemi	30 Ekim 2026
Ledger SHA-256	`9852c4e00a4c1b25165708541774ba23975ec6c97acd6e0c2b90c6377633f44c`
Kanıt commit'i	`937063c019bbe1d9d860b5bed64810c6f5256cb5`
Commit sayısı	17 gözden geçirilmiş geliştirme commit'i

Değerlendirme durumu

Ürün etkisi iddiası yoktur

Yerel oracle kararları ve izole laboratuvar gözlemleri, barındırılan bir hizmetin davranışı veya doğrulanmış bir ürün sapması olarak yorumlanmaz.

N/A	N/A	0
CWE	CVSS	ETKİ İDDİASI

Sonuç terimleri

Kabul ve **ret** yalnızca tanımlı test sözleşmesinin kararlarıdır. **Gözlem** ölçülmüş fakat tek başına uygunluk sonucu olmayan bir durumu; **atlandı** eksik önkoşulu; **sonuçsuz** ise eldeki kanıtın invariyantı çözmeye yetmediğini belirtir.

İçindekiler

01 Yönetici özeti

02 Kapsam ve iddia sınırları

03 Formal yöntem

04 Laboratuvar mimarisi

05 Workload Identity Federation

06 OAuth 2.0 Token Exchange

07 OpenID Connect

08 MS-PAC / MS-KILE

09 dMSA yaşam döngüsü

10 Cloud Kerberos Trust

11 Test stratejisi

12 Ampirik gözlemler

13 Kanıt bütünlüğü

14 Sınırlamalar

15 Mühendislik önerileri

A İnvariyant matrisi

B Gözlem indeksi

C Hash zinciri

D Commit zaman çizelgesi

E Yeniden üretim

F Terimler

G Kaynak indeksi

YÖNETİCİ ÖZETİ

Ölçülen, kanıtlanan ve özellikle iddia edilmeyenler

Program 1, kimlik protokollerinin farklı güven katmanlarını tek bir sonuç sınıfına sıkıştırmadan doğrular.

01

Çalışma, altı protokol alanındaki 37 kaynak-bağlı invariyantı çalıştırılabilir kararlara ve izole laboratuvar gözlemlerine dönüştürdü. Temel sonuç bir ürün bulgusu değil; kaynak, tip, zaman, durum ve kanıt sınırlarını birbirinden ayıran yeniden üretilebilir bir doğrulama sistemidir.

Doğrulama özeti: 37 formal invariyant, 25 normalize gözlem ve 198 test. Doğrulanmış ürün sapması bulunmadığı için CWE ve CVSS atanmadı.

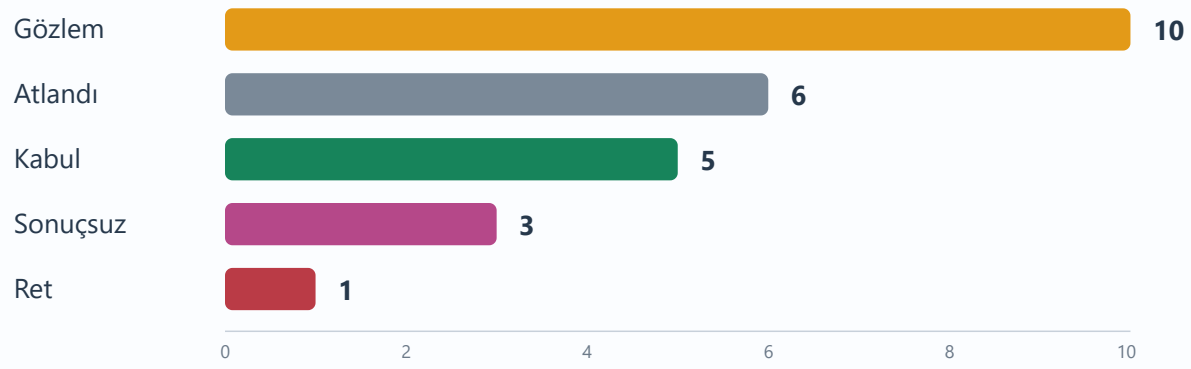
37
KATALOG KURALI
Her kural birincil kaynak, revizyon, bölüm ve kanıt sınıfına bağlıdır.

25
LEDGER KAYDI
Yalnızca normalize karar, neden kodu ve SHA-256 bağları tutulur.

148
UBUNTU TESTİ
Unit, property ve integration katmanları aynı derlemede geçti.

50
WİNDOWS TESTİ
Topoloji, forest, dMSA, PAC ve Cloud Trust kapıları geçti.

Şekil 1 - Normalize gözlem sonuç dağılımı n = 25



Ana mühendislik sonuçları

1. **Tip ayrımı korunmuştur.** String, array, integer ve boolean değerleri sessizce birbirine dönüştürülmez. Issuer, subject, audience ve NumericDate alanları kendi sözleşmeleri içinde değerlendirilir.
2. **Bağlam tamlığı açıkça modellenmiştir.** Tenant, application object, client ID, credential, issuer, subject matcher ve audience birlikte taşınmadığında bir federated identity seçimi tamamlanmış sayılmaz.
3. **Zaman kararı tek saatten üretilir.** Expiration, not-before, issued-at, auth-time, nonce saklama ve skew kararları enjekte edilen aynı saate bağlıdır; sınır eşitlikleri testlerle sabitlenmiştir.
4. **Token exchange çokluluğu kaybolmaz.** Tekil parametre tekrarları reddedilir; resource ve audience çokluluğu korunur; scope-target kartesyen ürünü eksikse karar kapanır.

5. **PAC ayrıştırma önce yapısal sınırları doğrular.** Descriptor sayısı, çarpım, sekiz bayt hizalama, offset-plus-size, overlap, SID ve signature şekilleri doğrulanmadan typed buffer sunulmaz.
6. **dMSA işlemi yalnızca komut dönüşüyle sınıflandırılmaz.** Migration state, reciprocal link, geçici ACL, enrollment, SPN/policy aktarımı, RWDC/RODC kaynağı ve restore digest birlikte incelenir.
7. **Cloud Kerberos kapısı kapalı varsayılanla çalışır.** Disposable tenant ve joined Windows 11 client bağlamı olmadan dış istek oluşturulmaz; RWDC-local durum client line-of-sight yerine geçmez.
8. **Kanıt zinciri tekrar üretilebilirdir.** Canonical JSONL ledger, kaynak manifestleri ve rapor, byte-level SHA-256 bağlarıyla birbirine bağlanmıştır.

> **En önemli yorum sınırı**
> Bir testin başarılı olması, Microsoft Entra veya Windows ürününün bütün olası dağıtımlarda aynı davranacağını kanıtlamaz. Başarı, yalnızca tanımlı oracle veya belirtilen Windows Server 2025 laboratuvar koşulunda invariyant testinin geçtiğini gösterir.

KAPSAM

Güven sınırları ve iddia sözleşmesi

Her karar, ait olduğu kanıt sınıfında anlam taşır; sınıflar arasında otomatik yükseltme yapılmaz.

02

Kapsanan protokol yüzeyleri

Alan	Normatif odak	Doğrulama biçimi	Katalog
Workload Identity Federation	RFC 7523 assertion, FIC bağlamı, typed claims, key-before-claim, zaman ve replay	Deterministik spec oracle + kapalı Entra gözlem kapısı	8
OAuth 2.0 Token Exchange	RFC 8693 required fields, actor atomikliği, target URI, rights product, lifetime	Typed request parser ve policy oracle	5
OpenID Connect	Issuer, audience, nonce ve ortak zaman ekseni	Deterministik ID token decision state machine	4
Cloud Kerberos Trust	Partial TGT, AzureADKerberos/PRP, line-of-sight, policy precedence	Read-only Windows prerequisite gate	4
MS-PAC / MS-KILE	Descriptor bounds, ordering, attributes, requestor, signatures, RODC, TGS ve DLG	Bounded parser + Windows service-ticket observation	8
dMSA	Reciprocal links, state, ACL, SPN/policy, enrollment, RWDC, events, rollback	Three-node AD graph observation	8

Dört kanıt sınıfı

spec-oracle

Kamuya açık protokol kuralından türetilen, ağ erişimi yapmayan typed karar. Bu sınıfın kabul/ret sonucu, yerel karar sözleşmesine aittir.

local-adapter

Bir implementasyon sınırından normalize edilen yapı veya bounded parser sonucu. Ham protokol materyali saklanmaz.

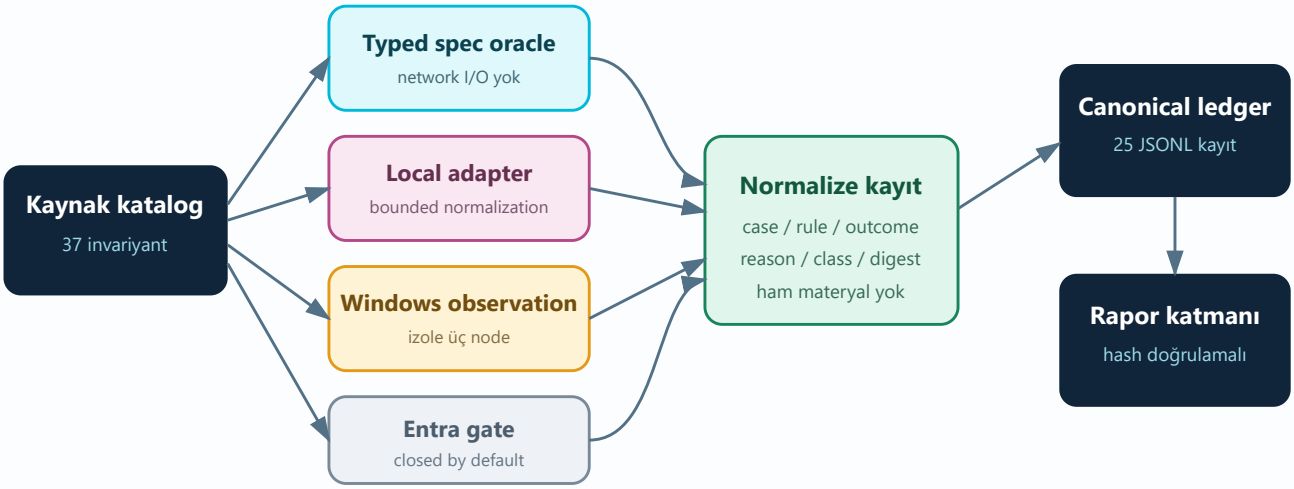
windows-observation

İzole Windows Server 2025 topolojisinde ölçülen durum. Ortam fingerprint'i ve checkpoint restore kapısı ile bağlanır.

entra-observation

Yalnızca disposable tenant, application, authority, budget ve redaction önkoşulları tam olduğunda açılan dış gözlem sınıfı. Bu çalışmada kapalı kaldı.

Şekil 2 - Kanıt sınıfları arasında yükseltmesiz veri akışı trust pipeline



İddia matrisi

İfade	Bu raporda yapılır mı?	Gerekçe
Yerel oracle belirtilen girdiyi kabul/ret eder.	Evet	Karar, typed input ve sabit kaynak kuralı ile yeniden üretilebilir.
Windows laboratuvarında belirtilen durum gözlendi.	Evet	Topoloji, checkpoint ve manifest fingerprint'i ile sınırlandırılmıştır.
Microsoft Entra barındırılan hizmeti şu şekilde davranır.	Hayır	Disposable tenant bağlamı yoktur; gate dış istek üretmeden kapanmıştır.
Bir ürün güvenlik sapması doğrulanmıştır.	Hayır	Bağımsız ürün davranışı ve etki doğrulaması yapılmamıştır.
CWE/CVSS atanmalıdır.	Hayır	Etki ve ürün yüzeyi doğrulanmadan sınıflandırma yapılmaz.

FORMAL YÖNTEM

Spesifikasyondan çalıştırılabilir invariyanta

Metinsel gereksinimler typed predicates, explicit clocks, bounded arithmetic ve normalize neden kodlarına dönüştürülür.

03

İnvariyant şeması

Her katalog girdisi yedi zorunlu semantik taşır: benzersiz rule ID, source ID, kaynak bölümü, kısa normatif özet, evidence class, en az bir positive case ve negative ya da observe case. Source ID ayrıca başlık, revizyon ve HTTPS primary URL ile bağlanır.

```
Invariant := (id, source, revision, section, summary, evidence_class, cases)
```

Bu bağ, test adının tek başına normatif anlam taşıdığı varsayımını ortadan kaldırır. Test, ancak hangi kaynak bölümünü ve hangi karar sınıfını temsil ettiğiyle birlikte denetlenebilir.

Karar fonksiyonunun özellikleri

Deterministik

Aynı typed input, aynı injected clock, aynı policy profile ve aynı source revision aynı karar ve reason code üretir.

Fail-closed

Eksik alan, tip belirsizliği, bilinmeyen reason code veya karşılanmayan önkoşul başarıya normalize edilmez.

Bağlam korunumu

Tenant, application, issuer, subject, audience, actor ve target gibi eksenler birbirine karıştırılmaz.

Kanıt sınıfı korunumu

Bir local-adapter sonucu windows-observation veya hosted-service iddiasına otomatik yükseltilmez.

Sınır değer yaklaşımı

Zaman, uzunluk ve offset kararlarında yalnızca tipik geçerli örnekler kullanılmadı. Eşitlik noktaları, bir önceki ve bir sonraki değer, negatif sayılar, boolean-as-integer durumu, aşırı descriptor sayısı, misalignment, overlap, duplicate singleton ve repeated identifier durumları property testlerle kapsandı.

```
accepted_time := (nbf − skew) <= now <= (exp + skew) AND iat <= (now + future_tolerance)
```

```
contained_region := offset % 8 == 0 AND 0 < size <= limit AND offset <= total − size
```

İkinci ifade, `offset + size` toplamını doğrudan hesaplamadan önce `offset <= total − size` biçiminde kontrol ederek sabit-width aritmetik için overflow-safe bir sözleşme kurar.

Reason code disiplini

Serbest metin hata mesajları kanıt formatına taşınmaz. Her karar enum ile tanımlı, bounded ve lower-case bir reason code kullanır. Bu yaklaşım; dil, platform veya exception metni değişse bile evidence diff'lerinin semantik kalmasını sağlar.

> **Negatif test ile ürün etkisi arasındaki ayrım**
> Bir oracle'ın girdiyi reddetmesi, gerçek bir hizmetin aynı girdiyi kabul ettiği veya bu farkın güvenlik etkisi taşıdığı anlamına gelmez. Ürün davranışı bağımsız olarak gözlenmeden karşılaştırmalı sonuç kurulmaz.

Katalog kapsamı

Kod	Alan	İnvariyant	Normalize gözlem
CKT	Cloud Kerberos Trust	4	4
DMSA	Delegated Managed Service Account	8	13
OIDC	OpenID Connect	4	0
PAC	MS-PAC / MS-KILE	8	6
STS	OAuth 2.0 Token Exchange	5	0
WIF	Workload Identity Federation	8	2

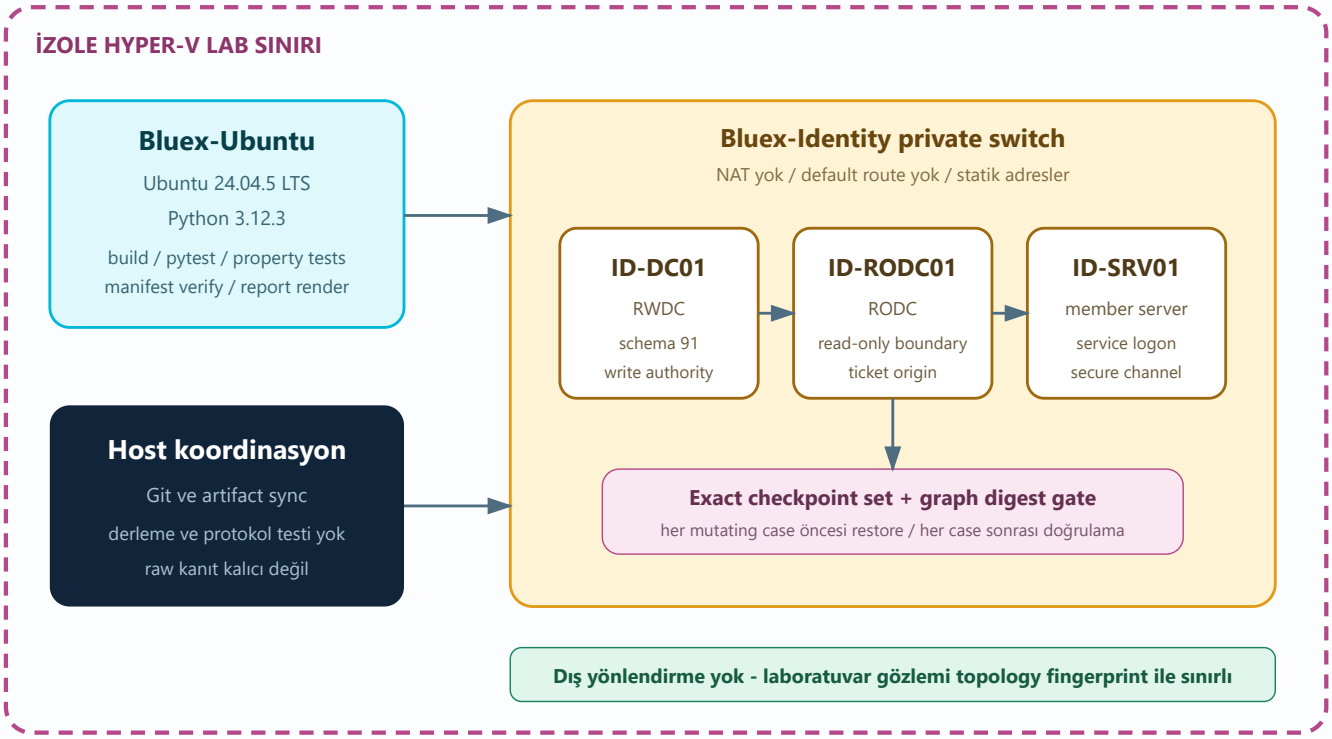
LABORATUVAR

İzole üç node Active Directory topolojisi

Derleme ve property testleri Ubuntu'da; directory, Kerberos ve dMSA gözlemleri private Hyper-V segmentinde yürütülür.

04

Şekil 3 - Çalıştırma ve kanıt topolojisi — host koordinasyon / VM doğrulama



Ortam fingerprint'i

Bileşen	Doğrulanmış değer
`seed`	20261030
`topology`	ID-DC01, ID-RODC01, and ID-SRV01 on private Bluex-Identity; no default route
`ubuntu`	Ubuntu 24.04.5 LTS; Python 3.12.3
`windows`	Windows Server 2025 build 26100; forest and domain mode 2025; schema 91

Mutasyon güvenliği

1. Mutating case başlamadan önce üç VM exact checkpoint setine döndürülür.
2. AD Web Services readiness ve domain health doğrulanır.
3. Baseline graph digest RWDC ve RODC perspektifinden kontrol edilir.

4. Member secure channel doğrulanır; varsayılan route bulunmadığı teyit edilir.
5. Case yürütülür, yalnızca allow-listed alanlar normalize edilir.
6. Raw ticket, token, credential ve directory response committed tree'ye girmez.
7. Case sonunda checkpoint restore ve digest doğrulaması tekrarlanır.

> **Restore sonucu**
> Exact checkpoint restoration, üç node için baseline graph digest'lerini yeniden üretti. dMSA Undo ve Reset işlemleri state ve linkleri geri getirse de member enrollment'ı temizledi; bu nedenle tam temizlik için checkpoint restore zorunlu kaldı.

WORKLOAD IDENTİTY FEDERATİON

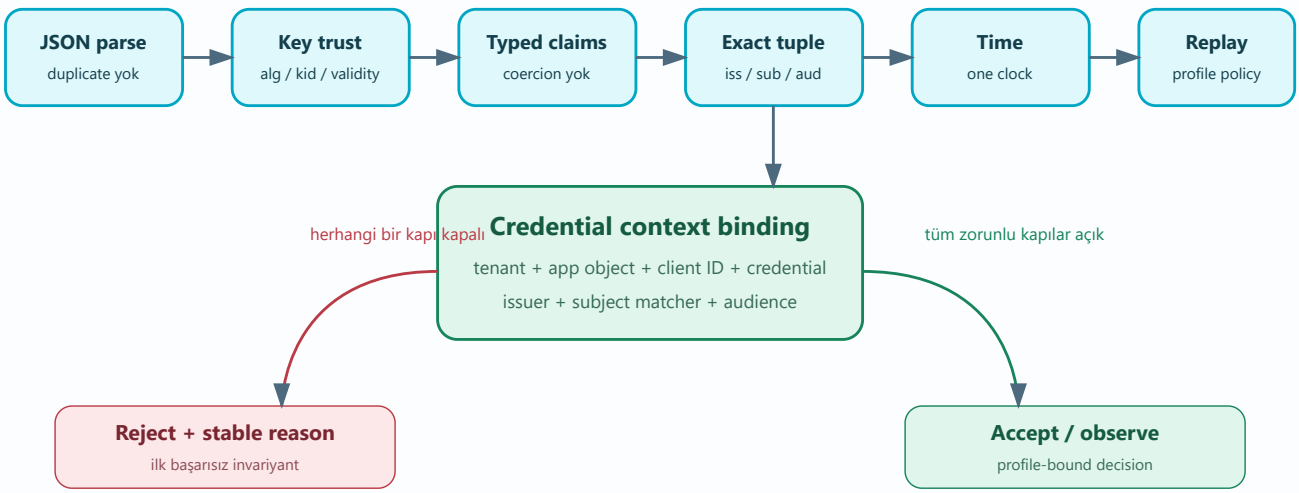
JWT assertion, FIC bağlamı ve typed claim sözleşmeleri

Karar sırası, anahtar güvenini claim eşlemesinden önce kurar; tip ve bağlam kaybını kabul etmez.

05

Federated credential seçimi yalnızca issuer-subject-audience üçlüsü değildir. Çalışma, seçim bağlamını tenant, application object, client ID, credential resource, issuer, subject matcher ve audience eksenlerinin tamamı olarak tanımlar.

Şekil 4 - JWT assertion değerlendirme durum makinesi RFC 7523 + FIC binding



Sekiz WIF invariyantı

ID	Sözleşme	Kritik ayrım
`WIF-TRANSPORT-001`	Client credentials akışı JWT bearer client assertion ve tek resource default scope kullanır.	RFC 8693 token-exchange request biçimi ile karıştırılmaz.
`WIF-TYPE-001`	Issuer/subject string, temporal claims NumericDate, audience scalar veya array semantiğinde kalır.	Boolean integer gibi kabul edilmez; object/string coercion yoktur.
`WIF-MATCH-001`	Standart issuer, subject ve audience karşılaştırmaları exact ve case-sensitive'dir.	Trailing slash, whitespace ve Unicode normalization sessizce uygulanmaz.
`WIF-BIND-001`	Credential seçimi tenant ve application context ile birlikte bağlanır.	Cross-tenant veya cross-application eşleşme tamamlanmış sayılmaz.
`WIF-TIME-001`	Expiration zorunludur; temporal kararlar tek injected clock ve explicit skew kullanır.	Farklı alanlar farklı saat okumaz.

ID	Sözleşme	Kritik ayrım
`WIF-REPLAY-001`	Repeated JWT ID, profile one-time use tanımlamıyorsa gözlem olarak kalır.	Spec gerektirmeden evrensel replay reddi uydurulmaz.
`WIF-FLEX-001`	Flexible credential subject veya desteklenen claim expression kullanır ve immutable anchor'ı korur.	Subject ile expression aynı anda etkin değildir.
`WIF-KEY-001`	Algorithm ve trusted issuer key doğrulaması claim policy'den önce tamamlanır.	Untrusted key ile doğru claim tuple'ı kabul edilmez.

Zaman ve replay modeli

Clock bağımlılığı constructor üzerinden enjekte edilir. Bu sayede expiration eşitliği, future issued-at toleransı ve nonce/JTI retention penceresi duvar saatine bağlı flaky testler olmadan ölçülür. Tekrar kullanım politikası profile-specific tutulur: bir profil repeated JTI'yi enforce edebilirken diğeri yalnızca observe edebilir.

> **Kapalı Entra gözlem kapısı**
> Disposable tenant context mevcut olmadığı için Ubuntu ve Windows gözlem yolları `tenant_context_missing` ile atlandı. Dış istek sayısı sıfır kaldı; bu atlama, canlı hizmet davranışına ilişkin olumlu veya olumsuz sonuç değildir.

RFC 8693

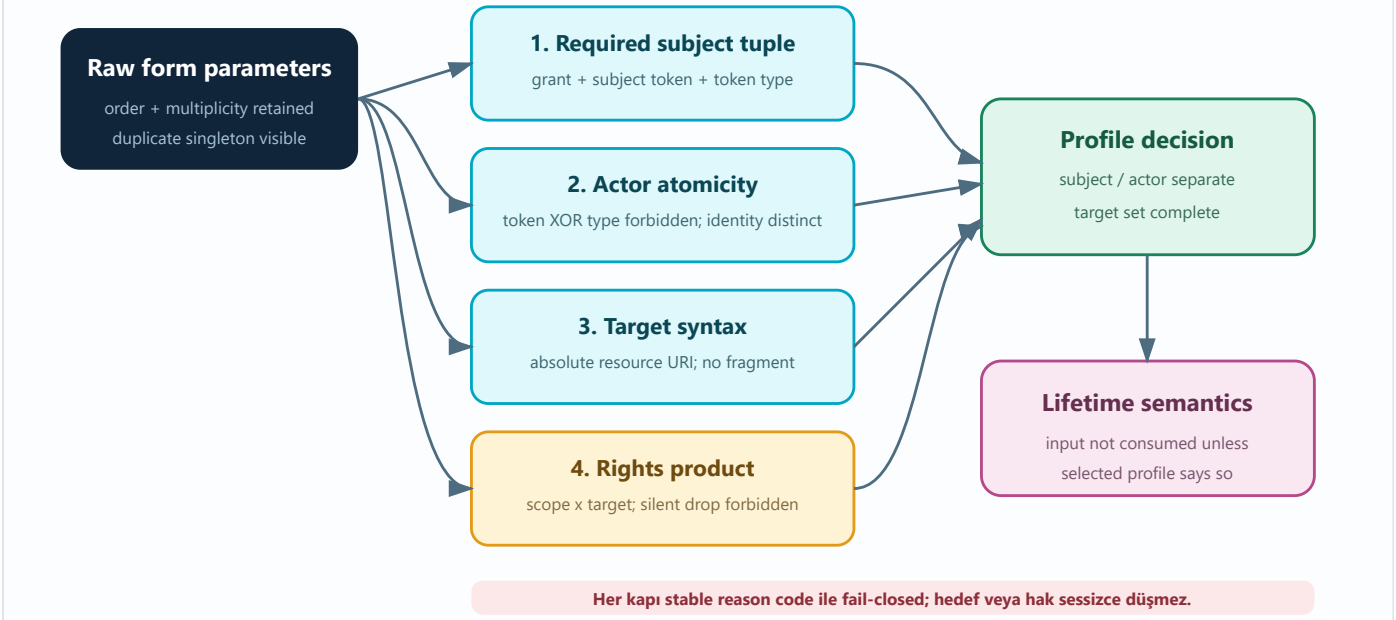
Token Exchange: çokluluk, actor ve rights product

Parser, request parametrelerini policy kararından önce kayıpsız ve tip güvenli biçimde normalleştirir.

06

RFC 8693 doğrulamasındaki ana risk, eksik alan kadar fazla alanın sessizce kaybolmasıdır. Uygulama repeated resource ve audience değerlerini korur; singleton tekrarlarını reddeder; actor token ile actor token type'ı atomik işler.

Şekil 5 - Token exchange karar akışı — request shape -> policy product



Beş temel sözleşme

ID	Predicate	Negatif sınırlar
STS-REQ-001	Grant type, subject token ve subject token type mevcut ve type-consistent.	Her zorunlu alanın tek tek eksikliği.
STS-ACTOR-001	Actor token/type birlikte bulunur; normalized actor subject ile aynı değildir.	Half pair ve collapsed identity.
STS-TARGET-001	Resource absolute, fragment-free URI; audience unambiguous identifier.	Relative URI, fragment ve ambiguous audience.
STS-RIGHTS-001	Requested rights, scope ve target'ın tam kartesyen ürününü korur.	Unauthorized pair ve silent target loss.
STS-LIFETIME-001	Input token consumption/coupling yalnızca seçili profile açıkça aitse uygulanır.	Spec'te olmayan global lifetime coupling.

Transport profile ayrımı

Entra WIF client credentials request ile RFC 8693 token exchange aynı HTTP form familyasını kullanabilse de semantik olarak farklı profillerdir. Harness, `grant_type`, assertion transport field'ları, subject token, actor token ve requested target alanlarını profil kimliğiyle birlikte değerlendirir. Böylece bir request'in yalnızca benzer parametre isimleri nedeniyle yanlış state machine'e girmesi engellenir.

OPENID CONNECT

Issuer, audience, nonce ve ortak zaman ekseni

ID token değerlendirmesi discovery issuer, registered client, sent nonce ve policy clock bağlamında yapılır.

07

OIDC karar sırası

1. **Issuer exact match:** Discovered issuer identifier ile token `iss` değeri byte-level string semantiğinde karşılaştırılır; case veya trailing slash normalizasyonu yapılmaz.
2. **Audience membership:** Registered client audience setinde bulunmalıdır. Ek audience varsa her ek değer explicit trusted set içinde olmalıdır.
3. **Nonce binding:** Authorization request'te nonce gönderildiyse ID token aynı nonce'u taşır. Kabul edilen nonce local replay policy içinde tek kullanımlık tüketilir.
4. **Temporal consistency:** `exp`, `iat`, isteğe bağlı `auth_time`, `max_age` ve nonce retention aynı injected clock'tan türetilir.

Audience invariant

```
client_id in aud AND (aud -
trusted_audiences) == empty
```

Client bulunması tek başına yeterli değildir; bilinmeyen ek audience kararın kapanmasına neden olur.

Nonce invariant

```
sent_nonce != null => token_nonce ==
sent_nonce AND consume_once(sent_nonce)
```

Gönderilen nonce'un token'da olmaması, farklı olması veya daha önce tüketilmiş olması ayrı reason code üretir.

Zaman sınırları

Property testler expiration sınırının skew sonrası exclusivity davranışını, not-before sınırının inclusivity davranışını, far-past ve future issued-at durumlarını ve boolean NumericDate girdilerini kapsar. `auth_time`, yalnızca `max_age` talep edildiğinde typed ve policy-bound bir zorunluluğa dönüşür.

> **Deterministik nonce expiry**
> Nonce store duvar saatini doğrudan okumaz. Test clock ilerletildiğinde tam retention sınırında karar tekrar üretilebilir; test suite zamanlamaya bağlı bekleme kullanmaz.

OIDC invariyant özeti

ID	Bağ	Temel negatif case
`OIDC-ISS-001`	Token issuer = discovered issuer	case-change, trailing slash
`OIDC-AUD-001`	Registered client present; no untrusted additional audience	client absent, untrusted extra

ID	Bağ	Temel negatif case
`OIDC-NONCE-001`	Sent nonce present, equal, fresh and consumed once	missing, mismatch, reuse
`OIDC-TIME-001`	exp/iat/auth_time/retention share one clock	expired, future iat, old auth_time

MS-PAC / MS-KILE

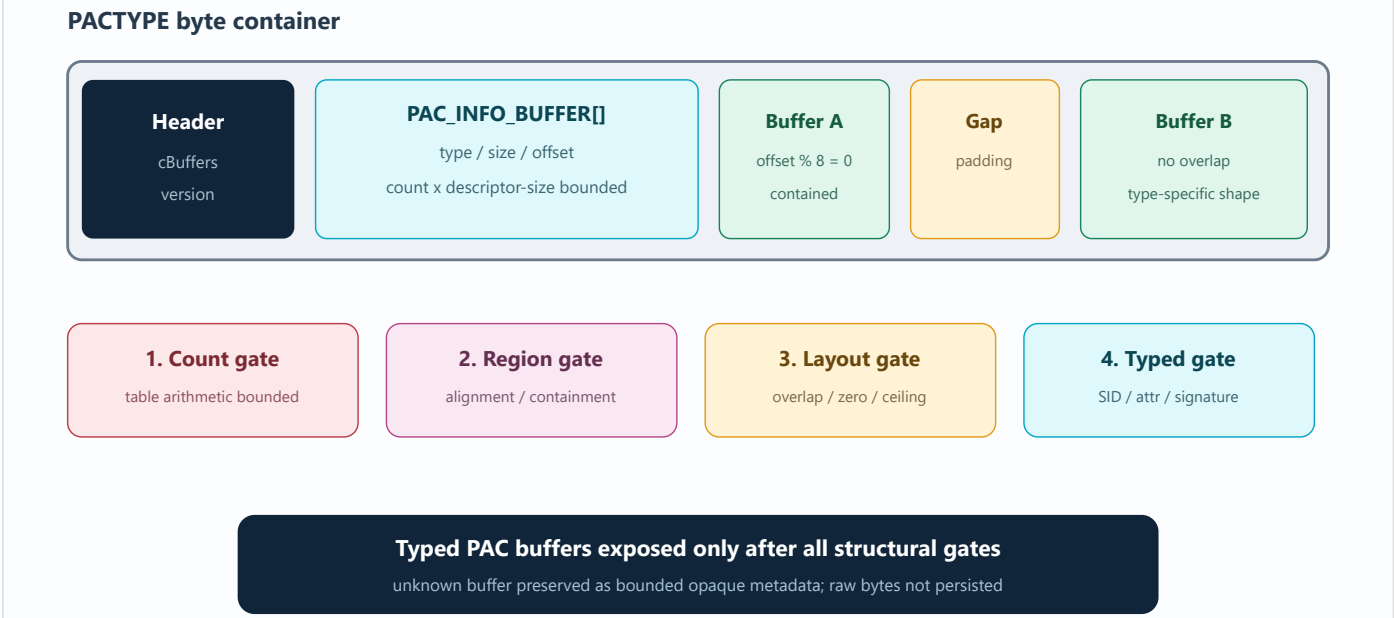
Bounded yapı ayrıştırma ve ticket-origin bağlamı

Parser, PACTYPE descriptor tablosunu ve her buffer bölgesini doğrulamadan typed içerik sunmaz.

08

PAC doğrulaması yalnızca buffer type listesini okumak değildir. Descriptor count, descriptor table arithmetic, sekiz bayt alignment, offset-size containment, overlap, per-buffer limit, SID exact length ve signature shape aynı yapısal güven sınırının parçalarıdır.

Şekil 6 - PACTYPE bounded region modeli — descriptor table + contained buffers



Yapısal invariyantlar

ID	Kontrol	Karar ayrıntısı
PAC-BOUNDS-001	Alignment ve contained region	Her offset sekiz bayt hizalı; offset-plus-size overflow-safe ve container içinde.
PAC-ORDER-001	Signature ordering	Server ve KDC signature konumları yapısal sözleşmeye göre değerlendirilir.
PAC-ATTR-001	PAC_ATTRIBUTES_INFO	32-bit flag rounding uygulanır; padding bitleri semantik flag sayılmaz.
PAC-REQ-001	PAC_REQUESTOR	SID revision, subauthority count ve exact buffer length birlikte doğrulanır.
PAC-SIG-001	Signature shape	Role, signature length ve context-bound identifier ayrıştırılır.
PAC-RODC-001	RODC identifier	KDC key version bağlamındaki RODC bileşeni ticket-origin ile ayrı tutulur.

ID	Kontrol	Karar ayrıntısı
PAC-TGS-001	TGS ticket construction	Service ticket issuance yalnızca bounded metadata ile gözlenir.
PAC-DLG-001	Domain-local processing	Gözlenen buffer seti grup işleme bağlamında normalize edilir; üyelik etkisi çıkarımsanmaz.

Windows ticket gözlemi

RWDC ve RODC kaynaklı service ticket'lar ayrı, bounded capture akışlarında işlendi. Cache isolation ve requested KDC eşleşmesi doğrulandı. Normalized kayıt, buffer type setini, signature role sırasını, attributes/requestor presence bitlerini ve RODC identifier bağlamını tuttu; ticket byte'ları, session key veya reusable principal identifier saklanmadı.

Gözlenen

Service ticket buffer seti, server/KDC/ticket/extended-KDC signature rolleri ve RODC KDC identifier bağlamı ölçüldü.

Çözülmeyen sınır

PAC requestor binding encrypted TGT içinde kaldığı için `PAC-REQ-001` bu laboratuvar kanıtıyla sonuçsuzdur. Service ticket gözlemi TGT requestor sonucuna yükseltilmedi.

Parser kaynak limitleri

Parser hem container toplam boyutuna hem descriptor sayısına hem de tekil buffer boyutuna üst sınır uygular. Büyük declared count, descriptor table aritmetiği yapılmadan reddedilir. Arbitrary bounded byte input property testi, parser'ın yalnızca ilan edilmiş hata sınıflarıyla çıkmasını ve hiçbir region'ın container dışına taşmamasını doğrular.

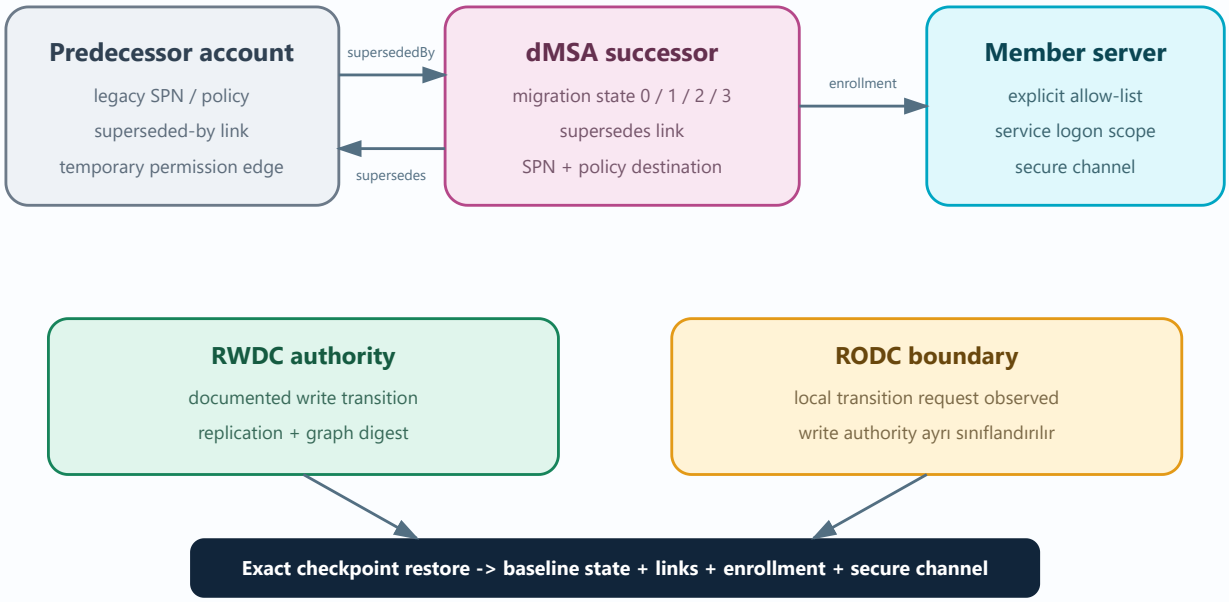
DELEGATED MANAGED SERVİCE ACCOUNT

Directory graph olarak yaşam döngüsü doğrulaması

Komut başarısı tek başına yeterli değildir; state, link, ACL, enrollment ve authority birlikte ölçülür.

09

Şekil 7 - dMSA migration graph ve otorite sınırı — predecessor / successor / member



Yaşam döngüsü invariyantları

ID	Graph predicate	Laboratuvar yorumu
`DMSA-LINK-001`	Predecessor ve successor reciprocal migration linkleri aynı ilişkiyi gösterir.	Replication sonrası reciprocal linkler gözlendi.
`DMSA-STATE-001`	Migration state yalnızca desteklenen sırada ilerler.	Start öncesi complete reddedildi; ordered completion kabul edildi; standalone state 3 gözlenmedi.
`DMSA-ACL-001`	Geçici migration permission edge yalnızca geçiş penceresine bağlıdır.	Ordered completion sonucu kabul edildi.
`DMSA-SPN-001`	Completion, SPN ve ilgili policy state'in successor'a aktarımını bağlar.	Completion graph'ında sözleşme sağlandı.
`DMSA-MACHINE-001`	Member enrollment explicit allow-list membership ile temsil edilir.	Enrollment edge açıkça gözlendi; dolaylı izin çıkarımı yapılmadı.

ID	Graph predicate	Laboratuvar yorumu
`DMSA-RWDC-001`	Writable directory authority ile RODC-local davranış ayrıdır.	RWDC transition kabul; RODC-local transition ayrı gözlem.
`DMSA-EVENT-001`	Audit event, directory state ve bounded observation window ile korele edilir.	Desteklenen event emission gözlenmedi; sonuçsuz.
`DMSA-ROLLBACK-001`	Cleanup state, link, ACL, enrollment ve baseline digest'in tamamını geri getirir.	Undo/Reset enrollment'ı temizledi; exact checkpoint restore digest match verdi.

Durum geçişi sonuçları

Başlangıç durumunda build-created account state 0 olarak kaldı. Start-to-complete sırası state, ACL ve SPN invariyantları için kabul edildi. Complete-before-start negatif case'i `invalid_transition` ile reddedildi. Dokümante standalone state 3, test edilen build 26100 koşulunda gözlenemedi; bu nedenle ürün genellemesi yapılmadan sonuçsuz bırakıldı.

Event korelasyonu

Direct service logon, local-system ticket refresh ve Service Control Manager pencereleri; enrolled member scope ve normalized event fields ile çalıştırıldı. Desteklenen dMSA event emission bu pencerelerde gözlenmedi. Yokluk, event'in hiçbir koşulda üretilmediği iddiasına çevrilmedi; `DMSA-EVENT-001` sonuçsuz kaldı.

> **Undo/Reset ile restore aynı işlem değildir**
> Undo ve Reset directory state/link görünümünü geri getirdi fakat machine enrollment edge'ini temizledi. Exact checkpoint restore ise state, link, enrollment, secure channel ve baseline graph digest'in tamamını yeniden üretti. Rapor, bu iki temizlik düzeyini ayrı sınıflandırır.

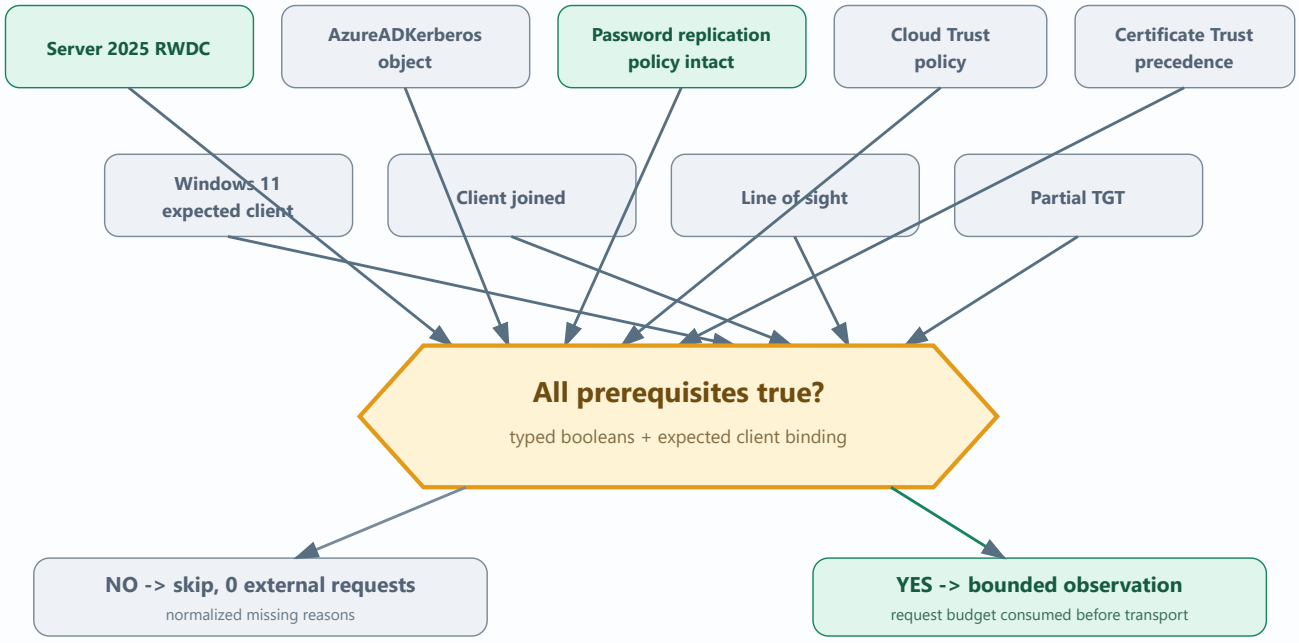
CLOUD KERBEROS TRUST

Dokuz koşullu, read-only ve kapalı önkoşul kapısı

RWDC-local varlıklar, joined Windows 11 client line-of-sight veya partial TGT kanıtı yerine geçmez.

10

Şekil 8 - Cloud Trust prerequisite gate — all conditions required



Kapı koşulları

Gate yalnızca boolean envanter kabul eder ve koşulları birbirinden bağımsız tutar: Server 2025 RWDC, AzureADKerberos object, password replication policy, Cloud Trust policy, Certificate Trust precedence, expected Windows 11 client, client joined durumu, client line-of-sight ve partial TGT. Beklenen client disabled veya unjoined ise remote probe yapılmaz.

R5 inceleme düzeltmesi

Bağımsız dal incelemesi, disabled veya unjoined expected client durumunda line-of-sight ve partial-TGT helper'larının çağrılmaması gerektiğini işaretledi. Önceki davranış iki odak testte başarısız olarak yeniden üretildi. Üretim kapısı, `Enabled`, `Windows11Client` ve `ClientJoined`

Bu koşudaki sonuç

İnvariyant	Sonuç	Neden	Yorum
`CKT-RODC-001`	Atlandı	`cloud_kerberos_object_missing`	AzureADKerberos object yok; PRP davranışı canlı bağlamda değerlendirilmedi.

İnvariyant	Sonuç	Neden	Yorum
`CKT-PRECEDENCE-001`	Atlandı	`cloud_trust_policy_unverified`	Policy seçimi doğrulanmadı; certificate-trust başarılı yol cloud-trust diye sınıflandırılmadı.
`CKT-LOS-001`	Atlandı	`line_of_sight_missing`	RWDC-local reachability, Windows 11 client line-of-sight yerine kullanılmadı.
`CKT-PARTIAL-001`	Atlandı	`partial_tgt_missing`	Partial TGT yok; full TGT zinciri hakkında sonuç kurulmadı.

Network side-effect sonucu

Kapalı Cloud Trust ve Entra bağlamlarında external request count sıfır kaldı. Skip kaydı, eksik önkoşulları ayrı reason code'larla korudu ve bir transport request inşa etmedi.

DOĞRULAMA

Unit, property, integration ve Windows contract testleri

Toplam 198 test, kaynak katalogdan PDF üretimine kadar farklı hata sınıflarını kapatır.

11

148
PYTEST
Unit, property ve integration testleri; üç conditional integration etkin.

50
PESTER
Preflight, topology, forest, dMSA, PAC ve Cloud Trust contract testleri.

0
BAŞARISIZ TEST
Son reviewed evidence commit'inde iki platform suite'i temiz.

Şekil 9 - Doğrulama katmanları kapsam haritası

koyu = doğrudan, açık = dolaylı/kapalı



Test katmanları

Katman	Örnek sözleşmeler	Başarısız olduğunda yakalanan sınıf
Unit	Exact issuer, duplicate singleton, key-before-claim, report escaping	Yerel state machine ve input validation hatası
Property	Temporal boundaries, claim types, PAC arithmetic, resource URI, redaction	Sınır değeri, tip coercion ve bounded arithmetic sapması
Integration	Closed Entra gate, Windows PAC adapter, evidence assembly, byte-stable report	Katmanlar arası bağlam veya provenance kaybı
Pester contract	Private topology, no default route, dMSA graph, PAC capture, Cloud gate	Windows orchestration ve mutation safety sapması

Katman	Örnek sözleşmeler	Başarısız olduğunda yakalanan sınıf
Artifact verification	Manifest digest, record count, source hash, secret-shape scan	Kanıt bütünlüğü veya public-safe boundary ihlali

Review-driven regression döngüsü

Bağımsız incelemede bulunan Cloud gate koşulu, BEFORE FAIL ve AFTER PASS kanıtıyla düzeltildi. Disabled expected client ve unjoined expected client testleri önce yanlış probe davranışını yakaladı; minimum gate değişikliği sonrasında odak suite 10/10, tam Windows suite 50/50 ve Ubuntu suite 148/148 geçti. Bu, rapordaki "zero external requests on closed context" iddiasının yalnızca tasarım niyeti değil, regresyonla sabitlenmiş davranış olduğunu gösterir.

AMPİRİK SONUÇLAR

25 normalize gözlemin teknik yorumu

Sonuç dağılımı tek başına skor değildir; her outcome yalnızca ilgili invariyant ve evidence class içinde okunur.

Sonuç dağılımı

5
KABUL
Ordered dMSA transitions, RWDC write ve exact restore.

1
RET
Complete-before-start invalid transition.

10
GÖZLEM
dMSA graph ve PAC service-ticket metadata.

9
AÇIK SINIR
6 skip + 3 inconclusive.

dMSA sonuç kümesi

- Reciprocal migration links replication sonrasında gözlendi.
- Member enrollment explicit allow-list edge olarak kaydedildi.
- Ordered completion; state, ACL ve SPN invariyantları için kabul edildi.
- Complete-before-start reddedildi ve directory mutation başarısı iddia edilmedi.
- RODC-local transition persisted durumu gözlem olarak ayrıldı; RWDC write authority ile eşitlenmedi.
- Standalone state 3 ve supported event emission, eldeki kanıtla sonuçsuz kaldı.
- Undo/Reset state ve linkleri geri getirdi ancak enrollment'ı temizledi; checkpoint restore baseline digest match verdi.

PAC sonuç kümesi

- RWDC ve RODC service ticket issuance bounded adapter üzerinden gözlendi.
- Gözlenen buffer type seti ve signature role sırası normalize edildi.
- RODC identifier yalnızca doğru KDC/signature context içinde yorumlandı.
- Service ticket'ta attributes buffer bulunmaması gözlem olarak kaydedildi; evrensel yokluk iddiası yapılmadı.
- Encrypted TGT içindeki requestor binding değerlendirilmediği için PAC requestor sonucu açık bırakıldı.

Cloud ve Entra kapıları

Dört Cloud Trust invariyantı eksik prerequisite nedeniyle, iki WIF live gate kaydı disposable tenant context eksikliği nedeniyle atlandı. Altı skip kaydı da dış istek oluşturmadan normalize edildi. Skip, başarısız ürün davranışı değildir; deneyin başlaması için gereken koşulun hazır olmadığını ispatlar.

Reason code yoğunluğu

Normalize neden	Kayıt
`allow_list_membership_is_explicit`	1
`attributes_buffer_absent`	1

Normalize neden	Kayıt
checkpoint_restore_digest_match	1
cloud_kerberos_object_missing	1
cloud_trust_policy_unverified	1
documented_state_three_not_observed	1
invalid_transition	1
line_of_sight_missing	1
ordered_completion	3
partial_tgt_missing	1
reciprocal_links_replicated	1
rodc_identifier_observed	1
rodc_local_transition_persisted	1
service_ticket_buffers_observed	1
service_ticket_issuance_observed	1
signature_roles_observed	1
state_links_restored_enrollment_cleared	2
supported_events_not_observed	1
tenant_context_missing	2
tgt_requestor_not_assessed	1
writable_directory_transition	1

Skorlamaya uygun olmayan dağılım

Accept sayısının yüksekliği veya skip sayısının düşüklüğü kalite skoru değildir. Katalogda bazı kurallar deterministic oracle ile test edilirken committed ledger yalnızca Windows/Entra observation katmanını içerir. Bu nedenle 37 kuralın 25 kayıtla bire bir olması beklenmez.

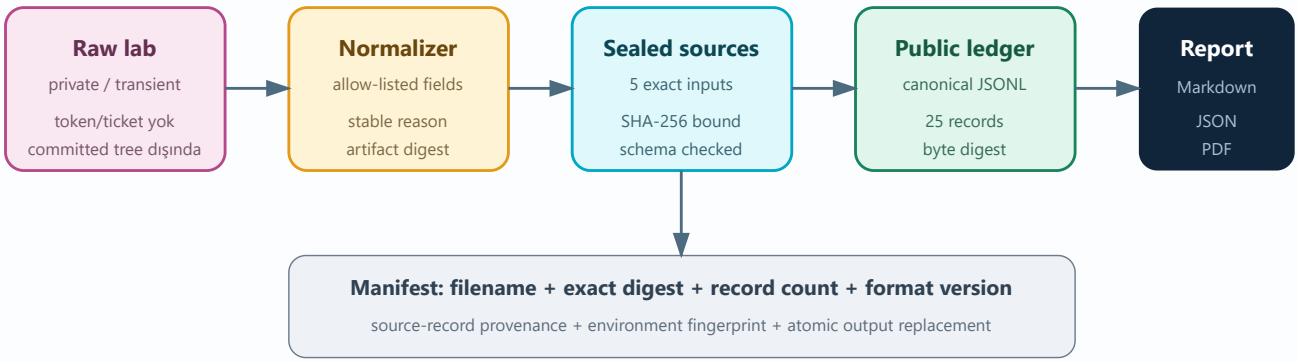
KANIT MÜHENDİSLİĞİ

Canonical ledger, source binding ve public-safe render

Kanıt doğruluğu yalnızca içeriğe değil, byte dizisine, kaynak record hash'ine ve atomik yazma davranışına bağlıdır.

13

Şekil 10 - Uçtan uca kanıt zinciri — source record -> report



Canonical serialization

Ledger satırları sorted key ve compact separator ile UTF-8/LF olarak yazılır. Her record, invariant ID, case ID, outcome, reason, evidence class, input digest, artifact digest ve bounded metadata taşır. Seal işleminden sonra append reddedilir. Manifest; ledger filename, exact SHA-256, record count ve format version alanlarını bağlar.

Public-safe filtreler

Persistence ve report render öncesinde private-key marker, bearer header, JWT-shaped value, credential-shaped field, local credential path, raw ticket/assertion alanı ve UUID-shaped reusable identifier taranır. Renderer yalnızca görünen metni değil, ledger'ın render edilmeyen metadata alanlarını da tarar. Unsafe output var olan raporun üzerine atomik olarak yazılmaz.

Deterministik render

- Katalog invariant ID'ye göre sıralıdır.
- Gözlemler rule, case, outcome ve reason sırasına göre düzenlenir.
- JSON key'leri ve mapping'ler sort edilir.
- HTML template yalnızca allow-listed placeholder'lar kabul eder.
- Build, 37/25 sayıları ve outcome dağılımı değişirse kapanır.
- Committed Markdown ve JSON, fresh render ile byte-for-byte karşılaştırılır.

Reviewed ledger

`9852c4e00a4c1b25165708541774ba23975ec6c97acd6e0c2b90c6377633f44c`

Bu digest, 25 canonical JSONL kaydının exact byte dizisine aittir. Rapor ekindeki source manifest ve artifact hash tablosu zincirin alt bileşenlerini listeler.

SINIRLAMALAR

Kanıtın çözmediği sorular

Belirsizliği saklamak, ölçülmeyen bir davranışı varsaymaktan daha güçlü bir mühendislik sonucudur.

14

Hosted Entra davranışı

Disposable tenant, application ve authority bağlamı sağlanmadı. Entra adapter kapalı gate'te iki skip kaydı üretti ve dış istek yapmadı. Bu nedenle issuer/audience/subject mapping'in barındırılan hizmetteki gerçek davranışı hakkında sonuç yoktur.

Cloud Kerberos end-to-end zinciri

AzureADKerberos object, selected Cloud Trust policy, joined Windows 11 client, client line-of-sight ve partial TGT hazır değildi. Cloud Trust sonuçları yalnızca prerequisite gate'in fail-closed davranışını kanıtlar; partial-to-full TGT dönüşümünü ölçmez.

PAC requestor sınırı

Service ticket PAC gözlemleri, encrypted TGT içindeki PAC_REQUESTOR binding'i çözmez. Bu nedenle `PAC-REQ-001` için service-ticket metadata'dan requestor sonucu türetilmedi.

dMSA state 3 ve event emission

Standalone state 3, build-created account ile gözlenmedi. Desteklenen event emission, üç kontrollü workload penceresinde görülmedi. Bu yokluklar, farklı build, policy veya service path'lerinde aynı sonucu garanti etmez.

Ortam genellenebilirliği

Windows gözlemleri Windows Server 2025 build 26100, forest/domain mode 2025, schema 91 ve private üç-node topolojiye bağlıdır. Farklı cumulative update, schema, trust, site, replication topology veya identity provider davranışı ayrı fingerprint gerektirir.

Değerlendirme sınırı

CWE ve CVSS atanmadı

Çalışma bir ürün sapması ve etkisini bağımsız olarak doğrulamadı. Yerel oracle farklılığı, skipped live gate veya sonuçsuz laboratuvar gözlemi tek başına güvenlik sınıflandırması için yeterli değildir.

SONRAKİ MÜHENDİSLİK ADIMLARI

Kanıt kapsamını güvenli biçimde genişletme

Öneriler, mevcut fail-closed ve public-safe sınırları zayıflatmadan gözlem çözünürlüğünü artırır.

15

Öncelik 1 - Disposable Entra bağlamı

1. Tek kullanımlık tenant ve application object'i açık owner/expiry politikasıyla oluştur.
2. Authority, tenant, application, client ve credential ID'lerini allow-list digest'leriyle bağla; reusable identifier'ları public evidence'a yazma.
3. Network request budget'i transport öncesi consume et ve response retention'ı mevcut allow-list ile sınırla.
4. Standard ve flexible FIC profillerini ayrı case setleriyle gözle; preview behavior'ı stable profile'a genelleme.
5. Koşu sonunda external resources için bağımsız cleanup manifest'i üret.

Öncelik 2 - Windows 11 Cloud Trust client

1. Expected client'i ayrı VM ve exact checkpoint ile oluştur.
2. Joined, enabled, Windows 11, line-of-sight ve policy result koşullarını client'tan ölç.
3. Partial TGT observation helper'ını bounded ve read-only tut; ticket byte'larını committed tree'ye taşımadan signature-chain metadata üret.
4. Certificate Trust precedence case'ini Cloud Trust case'inden bağımsız çalıştır.
5. Gate kapanışında external request count sıfır regresyonunu koru.

Öncelik 3 - PAC requestor çözünürlüğü

Encrypted TGT içindeki type-128 authorization-data region'ını izole, bounded ve ticket-byte retention olmadan doğrulayacak ayrı bir adapter tasarla. Service-ticket ve TGT kaynaklarını farklı evidence record'lara bağla; requestor SID yalnızca digest/shape metadata ile temsil edilsin.

Öncelik 4 - dMSA varyant matrisi

Build revision, forest functional level, member OS ve migration path eksenlerinde küçük bir varyant matrisi kur. Her varyant exact checkpoint seti ve graph digest taşımalı. State 3 veya event emission gözlenirse önce mevcut reason taxonomy genişletilmeli; serbest metin raporla sınıflandırma yapılmamalı.

Öncelik 5 - Uzun dönem kanıt sürdürülebilirliği

- Source revision değiştiğinde katalog diff review zorunlu kılınmalı.
- Manifest format version değişikliği geriye dönük parser testiyle gelmeli.
- Report builder, PDF extracted text ve representative page raster hash'leri CI dışı laboratuvar gate'inde doğrulanmalı.
- Environment fingerprint'e cumulative update ve PowerShell/Pester sürümü eklenmeli.
- Her yeni observation class için ayrı interpretation section yazılmalı.

EK A

Tam invariyant matrisi

Aşağıdaki 37 satır doğrudan katalog ve generated report modelinden üretilir.

ID	Alan	Normatif özet	Kaynak / bölüm	Sınıf	Case	Ledger sonucu
CKT-LOS-001	CKT	Domain controller line-of-sight is an explicit precondition for first use and on-premises resource access.	WHFB-CLOUD-TRUST Prerequisites and deployment validation	windows-observation	2	Atlandı
CKT-PARTIAL-001	CKT	The partial TGT carries the user SID and is verified by the on-premises domain controller before a full TGT is issued.	WHFB-AUTH Cloud Kerberos trust authentication	windows-observation	2	Atlandı
CKT-PRECEDENCE-001	CKT	Certificate trust policy precedence is recorded so its successful path is not classified as cloud trust.	WHFB-CLOUD-TRUST Policy configuration	windows-observation	2	Atlandı
CKT-RODC-001	CKT	The AzureADKerberos object retains RODC-like password replication restrictions for privileged identities.	WHFB-CLOUD-TRUST Azure AD Kerberos and password replication policy	windows-observation	3	Atlandı
DMSA-ACL-001	DMSA	Migration start grants documented temporary rights and completion removes them.	DMSA-OVERVIEW Account migration permissions	windows-observation	3	Kabul
DMSA-EVENT-001	DMSA	Operational events 307, 308, and 309 correlate migration, permission enrollment, and key fetch with directory snapshots.	DMSA-OVERVIEW Auditing dMSA activity	windows-observation	4	Sonuçsuz
DMSA-LINK-001	DMSA	Migration maintains the documented predecessor and successor link relation between the legacy account and dMSA.	DMSA-OVERVIEW Account migration	windows-observation	3	Gözlem
DMSA-MACHINE-001	DMSA	Only explicitly enrolled machine identities receive dMSA behavior and ticket refresh is a separate transition.	DMSA-SETUP Grant client access to the dMSA	windows-observation	3	Gözlem
DMSA-ROLLBACK-001	DMSA	Reset and undo cases restore a documented inactive or unlinked state without deleting the original account.	DMSA-SETUP Reset a dMSA account	windows-observation	3	Kabul Gözlem Gözlem
DMSA-RWDC-001	DMSA	Migration graph changes require a writable domain controller and an RODC observation never counts as a successful write.	DMSA-SETUP Prerequisites	windows-observation	2	Gözlem Kabul
DMSA-SPN-001	DMSA	Completion transfers SPNs and supported policy attributes before disabling and clearing the legacy account.	DMSA-OVERVIEW Account migration completion	windows-observation	3	Kabul
DMSA-STATE-001	DMSA	States one, two, and three mean started, completed, and standalone, with unsupported transition order rejected atomically.	DMSA-OVERVIEW Migration states	windows-observation	4	Ret Sonuçsuz Kabul
OIDC-AUD-001	OIDC	The audience includes the registered client and contains no untrusted additional audience.	OIDC-CORE 3.1.3.7	spec-oracle	4	Kayıt yok
OIDC-ISS-001	OIDC	The ID token issuer exactly matches the discovered issuer identifier.	OIDC-CORE 3.1.3.7	spec-oracle	3	Kayıt yok
OIDC-NONCE-001	OIDC	A sent nonce must match and is consumed once by the local bounded replay policy.	OIDC-CORE 3.1.2.1 and 3.1.3.7	spec-oracle	4	Kayıt yok
OIDC-TIME-001	OIDC	Expiration, issued-at, authentication time, and nonce retention share one injected clock and explicit skew.	OIDC-CORE 2 and 3.1.3.7	spec-oracle	4	Kayıt yok
PAC-ATTR-001	PAC	FlagsLength counts defined bits, storage is padded to 32-bit units, and undefined padding bits are ignored.	MS-PAC 2.14 PAC_ATTRIBUTES_INFO	local-adapter	3	Gözlem
PAC-BOUNDS-001	PAC	Every offset is eight-byte aligned and each offset-plus-size range is overflow-safe and contained in the PACTYPE.	MS-PAC 2.4 PAC_INFO_BUFFER	local-adapter	4	Kayıt yok
PAC-DLG-001	PAC	Applicable domain-local group processing removes requestor and attributes structures from the resulting service ticket.	MS-KILE Domain Local Group Membership processing	windows-observation	2	Gözlem

ID	Alan	Normatif özet	Kaynak / bölüm	Sınıf	Case	Ledger sonucu
PAC-ORDER-001	PAC	Buffer order is semantically free before signing and immutable after signatures are produced.	MS-PAC 2.8 PAC Signatures	local-adapter	2	Kayıt yok
PAC-REQ-001	PAC	A same-realm requestor SID resolves to the cname account while delegation identity remains separate.	MS-KILE TGS request PAC requestor validation	windows-observation	3	Sonuçsuz
PAC-RODC-001	PAC	RODCIdentifier is present only for an RODC-issued signature and maps to the documented key-version portion.	MS-PAC 2.8.1 PAC_SIGNATURE_DATA	windows-observation	3	Gözlem
PAC-SIG-001	PAC	Server, KDC, ticket, and extended KDC signature roles remain distinct and correctly ordered.	MS-PAC 2.8 PAC Signatures	local-adapter	3	Gözlem
PAC-TGS-001	PAC	A service ticket receives new server and KDC signatures and cannot end with a zero-length PAC buffer.	MS-KILE TGS ticket construction	windows-observation	3	Gözlem
STS-ACTOR-001	STS	Actor token and actor token type occur together while subject and actor identities remain distinct.	RFC8693 2.1	spec-oracle	4	Kayıt yok
STS-LIFETIME-001	STS	Exchange does not consume or tightly link the input token unless the selected token profile says otherwise.	RFC8693 2.1 and 2.2	spec-oracle	2	Kayıt yok
STS-REQ-001	STS	Grant type, subject token, and subject token type are required and type-consistent.	RFC8693 2.1	spec-oracle	4	Kayıt yok
STS-RIGHTS-001	STS	Requested rights preserve the full scope and target product without silently dropping a target.	RFC8693 2.1	spec-oracle	3	Kayıt yok
STS-TARGET-001	STS	Resource indicators are absolute fragment-free URIs and audience identifiers remain unambiguous.	RFC8693 2.1	spec-oracle	4	Kayıt yok
WIF-BIND-001	WIF	Credential selection remains bound to tenant, application object, client ID, credential, issuer, subject matcher, and audience.	ENTRA-FIC federatedIdentityCredential resource	spec-oracle	3	Atlandı Atlandı
WIF-FLEX-001	WIF	A flexible credential uses either subject or a supported claim expression and retains its immutable platform-claim binding.	ENTRA-FLEX-FIC Flexible federated identity credential configuration	spec-oracle	4	Kayıt yok
WIF-KEY-001	WIF	Algorithm and trusted issuer key validation complete before claim-based credential selection.	RFC7523 3.1 and 3.2	spec-oracle	4	Kayıt yok
WIF-MATCH-001	WIF	Standard federated credential issuer, subject, and audience comparisons are exact and case-sensitive.	ENTRA-FIC issuer subject and audiences properties	spec-oracle	5	Kayıt yok
WIF-REPLAY-001	WIF	Repeated JWT IDs are observations unless the selected profile explicitly defines one-time use.	RFC7523 3	spec-oracle	2	Kayıt yok
WIF-TIME-001	WIF	Expiration is required and all temporal decisions use one injected clock with explicit skew.	RFC7523 3.1 and 3.2	spec-oracle	5	Kayıt yok
WIF-TRANSPORT-001	WIF	Entra workload federation uses client credentials with a JWT bearer client assertion and one resource default scope.	ENTRA-CLIENT-CREDENTIALS Protocol diagram and access token request	spec-oracle	3	Kayıt yok
WIF-TYPE-001	WIF	Issuer and subject are strings, temporal claims are NumericDate numbers, and audience is interpreted without scalar coercion.	RFC7523 3	spec-oracle	4	Kayıt yok

"Kayıt yok", deterministic testin bulunmadığı anlamına gelmez; committed public ledger yalnızca normalize Windows/Entra gözlem kayıtlarını içerir. Spec oracle kapsamı test suite içinde doğrulanır.

EK B

Normalize gözlem indeksi

Her satır canonical ledger ile generated JSON report arasında bire bir doğrulanmıştır.

#	Case ID	Rule ID	Outcome	Reason	Evidence class
1	ckt-line-of-sight	CKT-LOS-001	Atlandı	line_of_sight_missing	windows-observation
2	ckt-partial-tgt-gate	CKT-PARTIAL-001	Atlandı	partial_tgt_missing	windows-observation
3	ckt-policy-precedence-gate	CKT-PRECEDENCE-001	Atlandı	cloud_trust_policy_unverified	windows-observation
4	ckt-rodc-object-gate	CKT-RODC-001	Atlandı	cloud_kerberos_object_missing	windows-observation
5	dmsa-started-to-complete--dmsa-acl-001	DMSA-ACL-001	Kabul	ordered_completion	windows-observation
6	dmsa-event-directory-correlation	DMSA-EVENT-001	Sonuçsuz	supported_events_not_observed	windows-observation
7	dmsa-reciprocal-migration-links	DMSA-LINK-001	Gözlem	reciprocal_links_replicated	windows-observation
8	dmsa-enrolled-machine	DMSA-MACHINE-001	Gözlem	allow_list_membership_is_explicit	windows-observation
9	dmsa-baseline-restore	DMSA-ROLLBACK-001	Kabul	checkpoint_restore_digest_match	windows-observation
10	dmsa-reset-to-documented-state	DMSA-ROLLBACK-001	Gözlem	state_links_restored_enrollment_cleared	windows-observation
11	dmsa-undo-to-documented-state	DMSA-ROLLBACK-001	Gözlem	state_links_restored_enrollment_cleared	windows-observation
12	dmsa-rodc-migration-write	DMSA-RWDC-001	Gözlem	rodc_local_transition_persisted	windows-observation
13	dmsa-rwdc-migration-write	DMSA-RWDC-001	Kabul	writable_directory_transition	windows-observation
14	dmsa-started-to-complete--dmsa-spn-001	DMSA-SPN-001	Kabul	ordered_completion	windows-observation
15	dmsa-complete-before-start	DMSA-STATE-001	Ret	invalid_transition	windows-observation
16	dmsa-standalone	DMSA-STATE-001	Sonuçsuz	documented_state_three_not_observed	windows-observation
17	dmsa-started-to-complete--dmsa-state-001	DMSA-STATE-001	Kabul	ordered_completion	windows-observation
18	pac-attributes-service-ticket	PAC-ATTR-001	Gözlem	attributes_buffer_absent	windows-observation
19	pac-domain-local-processing	PAC-DLG-001	Gözlem	service_ticket_buffers_observed	windows-observation
20	pac-requestor-tgt-boundary	PAC-REQ-001	Sonuçsuz	tgt_requestor_not_assessed	windows-observation
21	pac-rodc-identifier	PAC-RODC-001	Gözlem	rodc_identifier_observed	windows-observation
22	pac-signature-roles	PAC-SIG-001	Gözlem	signature_roles_observed	windows-observation
23	pac-service-ticket-issuance	PAC-TGS-001	Gözlem	service_ticket_issuance_observed	windows-observation
24	wif-live-gate-ubuntu-lab	WIF-BIND-001	Atlandı	tenant_context_missing	entra-observation
25	wif-live-gate-windows-lab	WIF-BIND-001	Atlandı	tenant_context_missing	entra-observation

EK C

Artifact ve source manifest hash zinciri

Digest'ler küçük harfli SHA-256 olarak verified machine-readable report'tan üretilir.

Artifact bağı	SHA-256
public-ledger	9852c4e00a4c1b25165708541774ba23975ec6c97acd6e0c2b90c6377633f44c
record/ckt-line-of-sight/source-ledger	464736fc7f5fe25bc775ef1e4097f23556f31775a5b912e7b44134a504cd6af0
record/ckt-line-of-sight/source-record	464736fc7f5fe25bc775ef1e4097f23556f31775a5b912e7b44134a504cd6af0
record/ckt-partial-tgt-gate/source-ledger	464736fc7f5fe25bc775ef1e4097f23556f31775a5b912e7b44134a504cd6af0
record/ckt-partial-tgt-gate/source-record	464736fc7f5fe25bc775ef1e4097f23556f31775a5b912e7b44134a504cd6af0
record/ckt-policy-precedence-gate/source-ledger	464736fc7f5fe25bc775ef1e4097f23556f31775a5b912e7b44134a504cd6af0
record/ckt-policy-precedence-gate/source-record	464736fc7f5fe25bc775ef1e4097f23556f31775a5b912e7b44134a504cd6af0
record/ckt-rodc-object-gate/source-ledger	464736fc7f5fe25bc775ef1e4097f23556f31775a5b912e7b44134a504cd6af0
record/ckt-rodc-object-gate/source-record	464736fc7f5fe25bc775ef1e4097f23556f31775a5b912e7b44134a504cd6af0
record/dmsa-baseline-restore/source-ledger	024bbf6c01333a08a383587cf701985d26dbe9eef975518aebc271e8f25ef9fc
record/dmsa-baseline-restore/source-record	10a41931157ea15bdae43f981795da94327ff117a128a05796e0942f903d5bf7
record/dmsa-complete-before-start/source-ledger	024bbf6c01333a08a383587cf701985d26dbe9eef975518aebc271e8f25ef9fc
record/dmsa-complete-before-start/source-record	afc7a6ccaaf23641982253a217521961bf4a0366b21dac9a1490fdcd48e53ed2
record/dmsa-enrolled-machine/source-ledger	024bbf6c01333a08a383587cf701985d26dbe9eef975518aebc271e8f25ef9fc
record/dmsa-enrolled-machine/source-record	3beadb0c4ead768999593cf42d6db1013d35dd24fa548600de6ee8e5cbafcb12
record/dmsa-event-directory-correlation/source-ledger	024bbf6c01333a08a383587cf701985d26dbe9eef975518aebc271e8f25ef9fc
record/dmsa-event-directory-correlation/source-record	5cd381882d94c9624fafb244712a2bb97c0e4f4cef442821fb729170904 1d82b
record/dmsa-reciprocal-migration-links/source-ledger	024bbf6c01333a08a383587cf701985d26dbe9eef975518aebc271e8f25ef9fc
record/dmsa-reciprocal-migration-links/source-record	5f3320bf5180927b7288ca6a515b9a30a3fdf84e508af2cc1e06a64058feb8e4
record/dmsa-reset-to-documented-state/source-ledger	024bbf6c01333a08a383587cf701985d26dbe9eef975518aebc271e8f25ef9fc
record/dmsa-reset-to-documented-state/source-record	89d931cf3e9dc280d5fe2a9fe5812ac3a2cf764a6c84fadeef7fcd640ec7132e
record/dmsa-rodc-migration-write/source-ledger	024bbf6c01333a08a383587cf701985d26dbe9eef975518aebc271e8f25ef9fc
record/dmsa-rodc-migration-write/source-record	4d014c3c70adaecd568f5d602f8acc03e2530d92412ba0ef48f86dfa3b67b929
record/dmsa-rwdc-migration-write/source-ledger	024bbf6c01333a08a383587cf701985d26dbe9eef975518aebc271e8f25ef9fc
record/dmsa-rwdc-migration-write/source-record	05ef5fb49d9003cde66457177b58dbbfa3271aed25864af982b3c0a7785cf135
record/dmsa-standalone/source-ledger	024bbf6c01333a08a383587cf701985d26dbe9eef975518aebc271e8f25ef9fc
record/dmsa-standalone/source-record	34800b16b0f8e89b88bbf9b6a725f354f65c3eaf22e8bad9d8b8b8bcb73747c2
record/dmsa-started-to-complete--dmsa-acl-001/source-ledger	024bbf6c01333a08a383587cf701985d26dbe9eef975518aebc271e8f25ef9fc
record/dmsa-started-to-complete--dmsa-acl-001/source-record	cf6e0bcb4faa2c6d3c886c5c9d15784043dd09035716980f4c7a5ad6c756417b
record/dmsa-started-to-complete--dmsa-spn-001/source-ledger	024bbf6c01333a08a383587cf701985d26dbe9eef975518aebc271e8f25ef9fc
record/dmsa-started-to-complete--dmsa-spn-001/source-record	cf6e0bcb4faa2c6d3c886c5c9d15784043dd09035716980f4c7a5ad6c756417b
record/dmsa-started-to-complete--dmsa-state-001/source-ledger	024bbf6c01333a08a383587cf701985d26dbe9eef975518aebc271e8f25ef9fc
record/dmsa-started-to-complete--dmsa-state-001/source-record	cf6e0bcb4faa2c6d3c886c5c9d15784043dd09035716980f4c7a5ad6c756417b
record/dmsa-undo-to-documented-state/source-ledger	024bbf6c01333a08a383587cf701985d26dbe9eef975518aebc271e8f25ef9fc
record/dmsa-undo-to-documented-state/source-record	d13a70bf1b23b13fae3b2c1cf4b44829144065 07cedce3945b09f8eb07ce1109
record/pac-attributes-service-ticket/source-ledger	3d1bda6af895f7de22eeaa5f6df5707c60d9ee6a631b507c226a309845707ffe

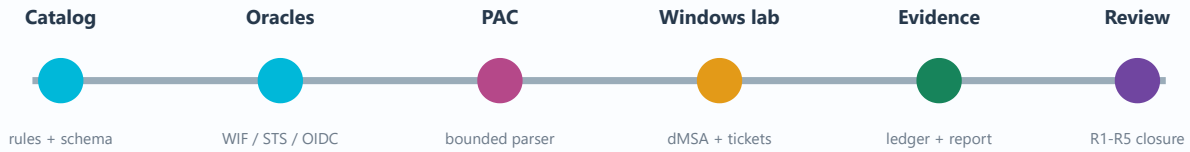
Artifact bağı	SHA-256
record/pac-attributes-service-ticket/source-record-rodc	d77d0ed8da9a12196794998e8c69ff19aba3012c80cc86c1b132d30314e534be
record/pac-attributes-service-ticket/source-record-rwdc	44f5e1a4644724f46b53971da784a2531a36453127015b539d4186bfd29e4e06
record/pac-domain-local-processing/source-ledger	3d1bda6af895f7de22eeaa5f6df5707c60d9ee6a631b507c226a3098457 07ffe
record/pac-domain-local-processing/source-record-rodc	d77d0ed8da9a12196794998e8c69ff19aba3012c80cc86c1b132d30314e534be
record/pac-domain-local-processing/source-record-rwdc	44f5e1a4644724f46b53971da784a2531a36453127015b539d4186bfd29e4e06
record/pac-requestor-tgt-boundary/source-ledger	3d1bda6af895f7de22eeaa5f6df5707c60d9ee6a631b507c226a3098457 07ffe
record/pac-requestor-tgt-boundary/source-record-rodc	d77d0ed8da9a12196794998e8c69ff19aba3012c80cc86c1b132d30314e534be
record/pac-requestor-tgt-boundary/source-record-rwdc	44f5e1a4644724f46b53971da784a2531a36453127015b539d4186bfd29e4e06
record/pac-rodc-identifier/source-ledger	3d1bda6af895f7de22eeaa5f6df5707c60d9ee6a631b507c226a3098457 07ffe
record/pac-rodc-identifier/source-record-rodc	d77d0ed8da9a12196794998e8c69ff19aba3012c80cc86c1b132d30314e534be
record/pac-rodc-identifier/source-record-rwdc	44f5e1a4644724f46b53971da784a2531a36453127015b539d4186bfd29e4e06
record/pac-service-ticket-issuance/source-ledger	3d1bda6af895f7de22eeaa5f6df5707c60d9ee6a631b507c226a3098457 07ffe
record/pac-service-ticket-issuance/source-record-rodc	d77d0ed8da9a12196794998e8c69ff19aba3012c80cc86c1b132d30314e534be
record/pac-service-ticket-issuance/source-record-rwdc	44f5e1a4644724f46b53971da784a2531a36453127015b539d4186bfd29e4e06
record/pac-signature-roles/source-ledger	3d1bda6af895f7de22eeaa5f6df5707c60d9ee6a631b507c226a3098457 07ffe
record/pac-signature-roles/source-record-rodc	d77d0ed8da9a12196794998e8c69ff19aba3012c80cc86c1b132d30314e534be
record/pac-signature-roles/source-record-rwdc	44f5e1a4644724f46b53971da784a2531a36453127015b539d4186bfd29e4e06
record/wif-live-gate-ubuntu-lab/source-ledger	9a6f96a6de428e34d2c1cd136fb3ebb631a82a33d7c3152748ca0ab028956b10
record/wif-live-gate-ubuntu-lab/source-record	5dbdab7652f42a2dcc3e9e4111ed2305b34361e9a585ab31c3994fb69b1c1395
record/wif-live-gate-windows-lab/source-ledger	683102d242f601909ae64bbff71c96ff09970e41fd842de5503e2182ee9215f7
record/wif-live-gate-windows-lab/source-record	31c45ebd581a1056cf3f3eb07e68591c71174b693c560efbb8c14e6c78ed8616
source-manifest/task7-windows-ledger	024bbf6c01333a08a383587cf701985d26dbe9eef975518aebc271e8f25ef9fc
source-manifest/task8-pac-ledger	3d1bda6af895f7de22eeaa5f6df5707c60d9ee6a631b507c226a3098457 07ffe
source-manifest/task9-cloud-gate	464736fc7f5fe25bc775ef1e4097f23556f31775a5b912e7b44134a504cd6af0
source-manifest/task9-ubuntu-ledger	9a6f96a6de428e34d2c1cd136fb3ebb631a82a33d7c3152748ca0ab028956b10
source-manifest/task9-windows-ledger	683102d242f601909ae64bbff71c96ff09970e41fd842de5503e2182ee9215f7

EK D

Geliştirme ve inceleme zaman çizelgesi

Liste reviewed evidence commit'ine kadar local Git history'den üretilir; bu raporun yayın commit'i döngüsel bağı önlemek için dahil değildir.

Şekil 11 - Program 1 mühendislik fazları — catalog -> lab -> evidence -> review



Her faz: test-first -> minimum change -> VM verification -> DCO commit

#	Commit	Tarih	Konu
1	`82c57c901e4a`	2026-10-30	chore: initialize identity invariant research
2	`91b8ee6dbeb2`	2026-10-30	test: define identity invariant catalog
3	`fc24b7cf26d5`	2026-10-30	feat: add typed assertion state machines
4	`48a16fb6917c`	2026-10-30	feat: model token exchange contracts
5	`910872f8cead`	2026-10-30	feat: record redacted invariant evidence
6	`7c46bbed99c5`	2026-10-30	feat: validate bounded PAC structures
7	`fdd6ad0bf322`	2026-10-30	lab: provision isolated identity topology
8	`06e0daf4abc3`	2026-10-30	test: verify dMSA lifecycle invariants
9	`9fec5c8da558`	2026-10-30	test: correlate PAC issuance contracts
10	`0d8770814a84`	2026-10-30	feat: gate live identity observations
11	`a83fbc95bced`	2026-10-30	docs: publish identity invariant evidence model
12	`413559db709a`	2026-10-30	fix: execute declared identity cases
13	`0746bbf92164`	2026-10-30	fix: preserve identity evidence provenance
14	`5700f5b0258b`	2026-10-30	fix: close live observation state gates
15	`4a4524a20688`	2026-10-30	fix: harden identity evidence boundaries
16	`122c87bfbb29`	2026-10-30	fix: bind cloud probes to joined clients
17	`937063c019bb`	2026-10-30	docs: rebuild reviewed identity evidence

EK E

Yeniden üretim ve doğrulama komutları

Derleme ve testler yalnızca izole VM'lerde yürütülür; host Git ve artifact koordinasyonuyla sınırlıdır.

Ubuntu test ve manifest doğrulaması

```
python3 -m venv .venv
.venv/bin/python -m pip install --require-hashes -r requirements-dev.lock
PYTHONPATH=src .venv/bin/python -m pytest -q
PYTHONPATH=src .venv/bin/python -m compileall -q src tests tools
PYTHONPATH=src .venv/bin/python -m identity_invariants.reports.render --verify-only evidence/manifest.json
```

Deterministik machine-readable report

```
PYTHONPATH=src .venv/bin/python -m identity_invariants.reports.render \
  --render evidence/manifest.json \
  --catalog spec/invariants.yaml \
  --output reports/identity-invariants.md
```

Detaylı HTML raporu

```
PYTHONPATH=src .venv/bin/python tools/build_detailed_report.py \
  --root . \
  --template reports/program1-detailed-report.template.html \
  --output reports/program1-detailed-report.html \
  --data-output reports/program1-detailed-report-data.json
```

Windows contract testleri

```
Invoke-Pester -Path .\lab\windows\tests -PassThru
```

PDF bağımsız kontrolü

```
pdfinfo reports/program1-detailed-report.pdf
pdftotext -layout reports/program1-detailed-report.pdf /tmp/program1-report.txt
sha256sum reports/program1-detailed-report.pdf
```

Önkoşul

Windows mutating laboratuvar case'leri yalnızca exact three-node checkpoint seti, private switch, no-default-route, ADWS readiness, graph digest ve secure-channel kapıları geçtikten sonra yürütülmelidir.

EK F

Terimler ve karar sözlüğü

Rapor boyunca kullanılan teknik sözcüklerin bağlama özgü anlamları.

Terim	Bu rapordaki anlamı
İnvariyant	Kaynak bölümü, typed predicate, evidence class ve case setiyle sabitlenen doğrulanabilir sözleşme.
Oracle	Network I/O yapmadan typed input üzerinde deterministic karar veren yerel state machine.
Adapter	Bir dış veya platform sınırındaki veriyi allow-listed, bounded metadata'ya dönüştüren katman.
Evidence class	Bir kararın hangi güven düzeyinde yorumlanacağını belirleyen sınıf.
Accept	Belirtilen yerel veya laboratuvar sözleşmesinin positive predicate'i sağlandı.
Reject	Belirtilen negative predicate doğru reason code ile kapandı.
Observe	Durum ölçüldü; tek başına uygunluk veya ürün etkisi sonucu değildir.
Skip	Gerekli bağlam yok; deney başlamadan fail-closed sonuç üretildi.
Inconclusive	Retained evidence invariyantı çözmeye yetmedi.
Canonical JSONL	Sorted keys, compact separators, UTF-8 ve LF ile byte-stable record serialization.
Source manifest	Normalize kaynak artifact'ının exact SHA-256 bağını taşıyan belge.
Graph digest	dMSA ve topology state'inin normalize, sıralı görünümünden üretilen karşılaştırma özeti.
Line-of-sight	Beklenen joined Windows client'ın on-prem domain controller ile gerekli erişim bağlamı.
Partial TGT	Cloud Kerberos Trust akışında on-prem doğrulamadan önceki sınırlı ticket aşaması.
RODC identifier	KDC key version ve PAC signature bağlamında ayrı yorumlanan read-only domain controller bileşeni.

EK G

Normatif ve teknik kaynak indeksi

Kaynak başlığı, raporda kullanılan sabit revizyon tanımı ve primary HTTPS adresi.

ID	Başlık	Revizyon	Primary URL
DMSA-OVERVIEW	Delegated Managed Service Accounts overview	Windows Server 2025 documentation	https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/manage/delegated-managed-service-accounts/delegated-managed-service-accounts-overview
DMSA-SETUP	Set up delegated Managed Service Accounts	Windows Server 2025 documentation	https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/manage/delegated-managed-service-accounts/delegated-managed-service-accounts-set-up-dmsa
ENTRA-CLIENT-CREDENTIALS	Microsoft identity platform OAuth 2.0 client credentials flow	Microsoft identity platform v2.0 endpoint	https://learn.microsoft.com/en-us/entra/identity-platform/v2-oauth2-client-creds-grant-flow
ENTRA-FIC	Microsoft Graph federated identity credential overview	Microsoft Graph REST API v1.0	https://learn.microsoft.com/en-us/graph/api/resources/federatedidentitycredentials-overview?view=graph-rest-1.0
ENTRA-FLEX-FIC	Flexible federated identity credentials	Microsoft Entra workload identities public preview	https://learn.microsoft.com/en-us/entra/workload-id/workload-identities-flexible-federated-identity-credentials
MS-KILE	Kerberos Protocol Extensions	MS-KILE Open Specifications current revision, accessed 2026-10-30	https://learn.microsoft.com/en-us/openspecs/windows_protocols/ms-kile/
MS-PAC	Privilege Attribute Certificate Data Structure	MS-PAC Open Specifications current revision, accessed 2026-10-30	https://learn.microsoft.com/en-us/openspecs/windows_protocols/ms-pac/
OIDC-CORE	OpenID Connect Core 1.0 incorporating errata set 2	OpenID Connect Core 1.0, errata set 2	https://openid.net/specs/openid-connect-core-1_0.html
RFC7523	JSON Web Token Profile for OAuth 2.0 Client Authentication and Authorization Grants	RFC 7523, May 2015	https://datatracker.ietf.org/doc/html/rfc7523
RFC8693	OAuth 2.0 Token Exchange	RFC 8693, January 2020	https://datatracker.ietf.org/doc/html/rfc8693
WHFB-AUTH	Windows Hello for Business authentication	Windows Server 2025 documentation	https://learn.microsoft.com/en-us/windows/security/identity-protection/hello-for-business/how-it-works-authentication
WHFB-CLOUD-TRUST	Hybrid cloud Kerberos trust deployment	Windows Server 2025 documentation	https://learn.microsoft.com/en-us/windows/security/identity-protection/hello-for-business/deploy/hybrid-cloud-kerberos-trust

Son not: Bu rapor public-safe normalize kanıtı açıklar. Ham assertion, token, Kerberos ticket, PAC byte dizisi, private key, directory credential, reusable identifier veya tam service response içermez.

© 2026 Adil Alperen Çiftci. Teknik doğrulama belgesi.